TOPIC 1 · MALWARE IN PLAIN WORDS

10 minutes · what malware is · six families · how it arrives · why fake APKs are the biggest risk for citizens

What is it?

Malware (malicious software) is any program designed to harm a device, spy on its user or steal from them. For most citizens in India, the biggest risks are **fake Android apps (APKs)** sent by link — "electricity bill", "KYC update", "wedding invitation", "traffic challan" — and **real screen-sharing apps** installed because a scammer asked.

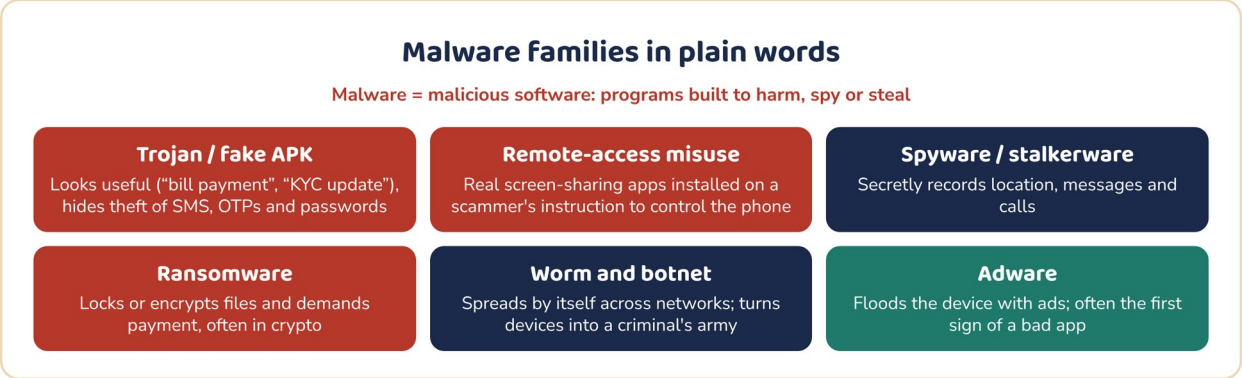


Figure 8.3 · Malware families in plain words

How malware arrives	Example	Prevention
Link to an APK file	"Download the bill app to avoid disconnection"	Install only from Google Play or the App Store; block unknown sources
Scammer-guided install	"Install this support app so I can help you with KYC"	Never install apps on a caller's instruction
Email attachment or fake invoice	"Invoice_Oct.zip" on an office computer	Do not open unexpected attachments; verify with the sender
Pirated software and cracked games	Free "premium" software	Use licensed or free official software
Unpatched systems	Old router or Windows version without updates	Automatic updates on

Real-life case · the wedding invitation

Mr Thomas received a WhatsApp message from an unknown number: "Wedding invitation — open the card". The file was an APK. After installing it, his phone began forwarding SMS to the criminals. That night, OTPs were used to add his card to a payment wallet and ₹62,000 was spent.

Lesson: an invitation is a picture or PDF, never an app. Any file ending in .apk sent on chat is a red flag.

Scammed? Call 1930 or file a complaint at cybercrime.gov.in

TOPIC 2 · SIGNS OF COMPROMISE

8 minutes · phone signs · computer signs · account signs · accessibility abuse · email forwarding rules

What is it?

Compromise rarely announces itself, except in ransomware. Most signs are small: OTPs you did not request, a phone that heats up while idle, a recovery email that has changed. One sign is a reason to check carefully; several together call for isolation.

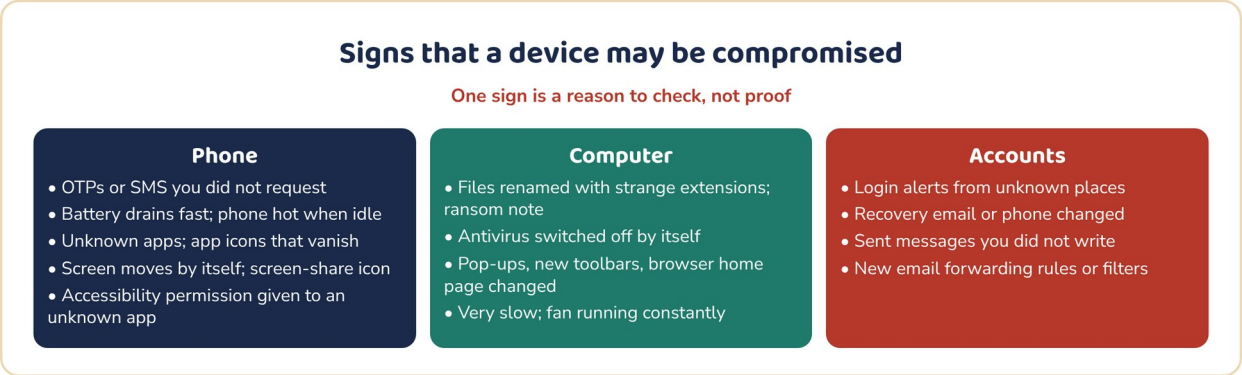


Figure 8.4 · Signs that a device may be compromised

Scammed? Call 1930 or file a complaint at cybercrime.gov.in

Community Cyber First Responder · CyberPeace Foundation × SAKEC, Mumbai · CC BY-SA 4.0

Two signs experts check first

- **Accessibility permission (Android):** malicious apps ask for it because it lets them read the screen and tap buttons. Settings → Accessibility → check for any app you do not recognise.
- **Email forwarding rules:** after taking over an email account, criminals often add a rule that silently forwards bank and security emails to themselves — and keep it even after the password is changed. Check the email settings for forwarding and filters.

Ask yourself

- Did OTPs, alerts or messages arrive that the person did not expect?
- Is there an app the person does not remember installing, or one with accessibility or admin rights?
- Have recovery details, forwarding rules or logged-in devices changed?

Stop	Save	Report
Disconnect the device (Topic 3); stop any ongoing call with a “helper”.	Photograph the screen and app list with another phone; note times.	Bank and 1930 if money is involved; route as per the triage colour.

Remember

Several small signs together mean: isolate first, investigate later — by the right people.

Scammed? Call 1930 or file a complaint at cybercrime.gov.in

Community Cyber First Responder · CyberPeace Foundation × SAKEC, Mumbai · CC BY-SA 4.0

TOPIC 3 · ISOLATE AND PRESERVE

10 minutes · disconnect · do not wipe · photograph · clean device · hand over

What is it?

Isolation cuts the attacker's connection to the device; **preservation** keeps the device as it is so that the police or IT lead can examine it. Both are done in the first ten minutes. The instinct to reset, uninstall or run a "cleaner" app must be resisted until the case has been routed.

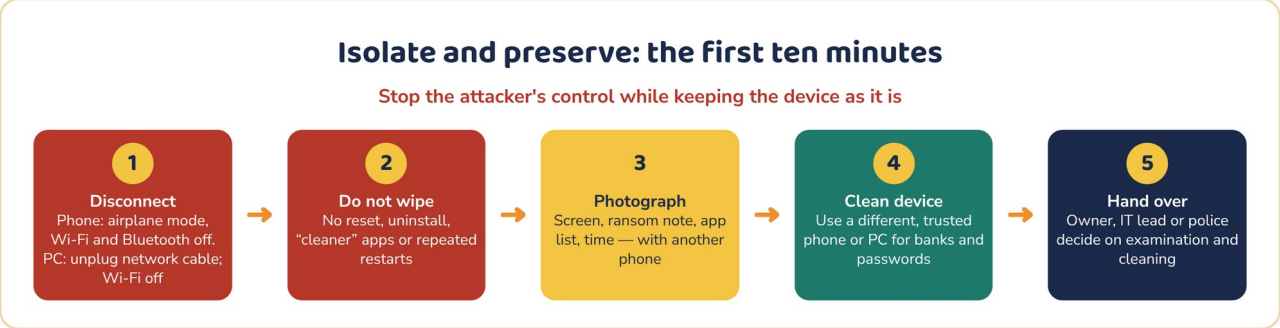


Figure 8.5 · Isolate and preserve: the first ten minutes

Device	Isolate	Preserve
Android or iPhone	Airplane mode; check Wi-Fi and Bluetooth are off	Do not uninstall or reset; photograph the app list and suspicious screens; keep it charged
Windows or Mac computer	Unplug the network cable; turn Wi-Fi off; unplug USB drives	Do not shut down repeatedly; photograph the screen; note time and user
Shared office network	IT lead disconnects affected machines or segment	Note which machines are affected and when

Remember

Disconnect — do not wipe. A reset may remove the attacker, but it also removes the evidence and may leave stolen accounts open.

Scammed? Call 1930 or file a complaint at cybercrime.gov.in

TOPIC 4 · ACCOUNT RECOVERY AND LOCKDOWN

12 minutes · clean device · official recovery routes · sign out other sessions · MFA · recovery details · warn contacts

What is it?

When an account has been taken over, recovery must be done from a **clean device** — one the attacker has never controlled — using **official recovery routes**. Recovery is not complete until the attacker is locked out: all other sessions signed out, a new unique password set, MFA turned on, recovery details corrected and hidden settings checked.

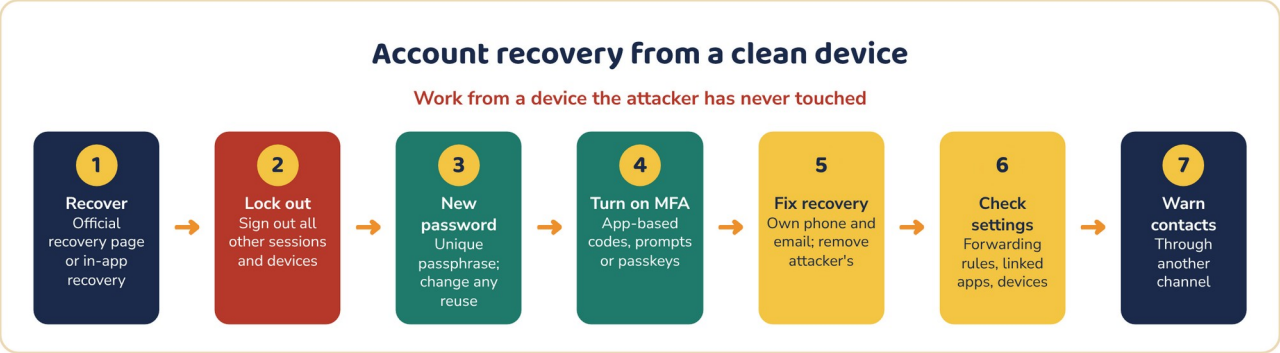


Figure 8.6 · Account recovery from a clean device

Scammed? Call 1930 or file a complaint at cybercrime.gov.in

Account	Official recovery route	Lockdown checks
Google / Gmail	g.co/recover; then myaccount.google.com → Security	Your devices → sign out unknown; 2-Step Verification; recovery phone and email; Gmail forwarding and filters
WhatsApp	Re-register the number on the phone and enter the SMS code. If the attacker set a two-step PIN, WhatsApp may require a waiting period before it can be reset	Turn on two-step verification; check Linked devices; warn contacts; email WhatsApp support to deactivate if the phone is lost
Instagram / Facebook	instagram.com/hacked · facebook.com/hacked	Log out of all sessions; two-factor authentication; check email and phone on the account; remove unknown linked apps
UPI and banking apps	Bank helpline from the card number; block UPI and cards	Reset UPI PIN only after the bank confirms the phone is safe; review linked accounts

Why the email account comes first

Most other accounts reset their passwords by email. If the attacker still controls the email, they can take back everything else. Secure the email first, then the accounts that depend on it.

Scammed? Call 1930 or file a complaint at cybercrime.gov.in

Community Cyber First Responder · CyberPeace Foundation × SAKEC, Mumbai · CC BY-SA 4.0

TOPIC 5 · SIM SWAP AND BANKING TROJANS

8 minutes · how SIM swap works · trojans that read OTPs · response order · prevention

What is it?

In a **SIM swap**, a criminal gets a new SIM issued for the victim's number — by fraud at a store or by tricking the victim into a "SIM upgrade" — and then receives all OTPs. A **banking trojan** reads OTPs and screens directly on the victim's phone. Both often come together with a hijacked email account. The sign is a phone that suddenly shows "No Service", or OTPs and debits the person did not initiate.

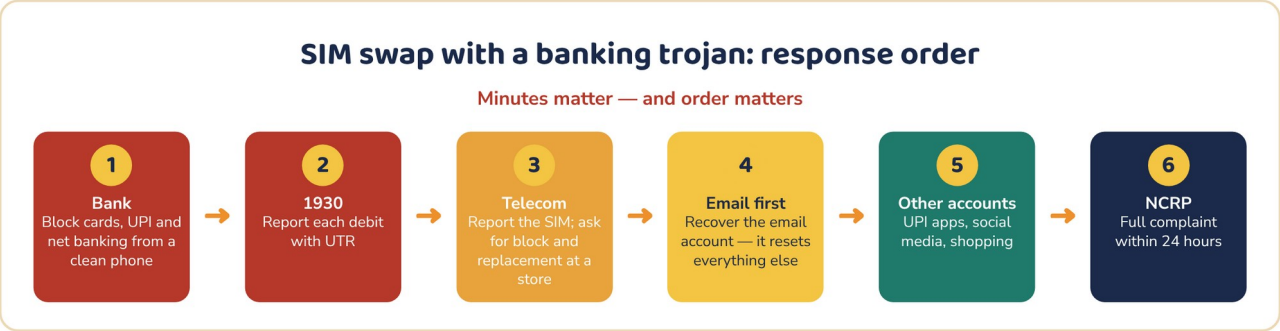


Figure 8.7 · SIM swap with a banking trojan: response order

Prevention	How
Never "upgrade" a SIM on a phone call	Telecom companies do not ask you to send SMS or codes to upgrade to 5G
Know your connections	Check SIMs in your name on Sanchar Saathi; report unknown ones
App-based MFA	Prefer app prompts or passkeys over SMS codes for email
Act on "No Service"	If the phone loses service unexpectedly, call the telecom provider and bank from another phone at once

Scammed? Call 1930 or file a complaint at cybercrime.gov.in

Community Cyber First Responder · CyberPeace Foundation × SAKEC, Mumbai · CC BY-SA 4.0

TOPIC 6 · RANSOMWARE IN SMALL ORGANISATIONS, AND PREVENTION

12 minutes · contain and escalate · CERT-In · why not to pay · No More Ransom · 3-2-1 backups · Cyber Swachhta Kendra

What is it?

Ransomware encrypts files and demands payment. Schools, clinics, shops and small offices are frequent victims because they often lack backups and IT staff. The First Responder's job is to contain, escalate and record — never to negotiate, pay or attempt decryption.

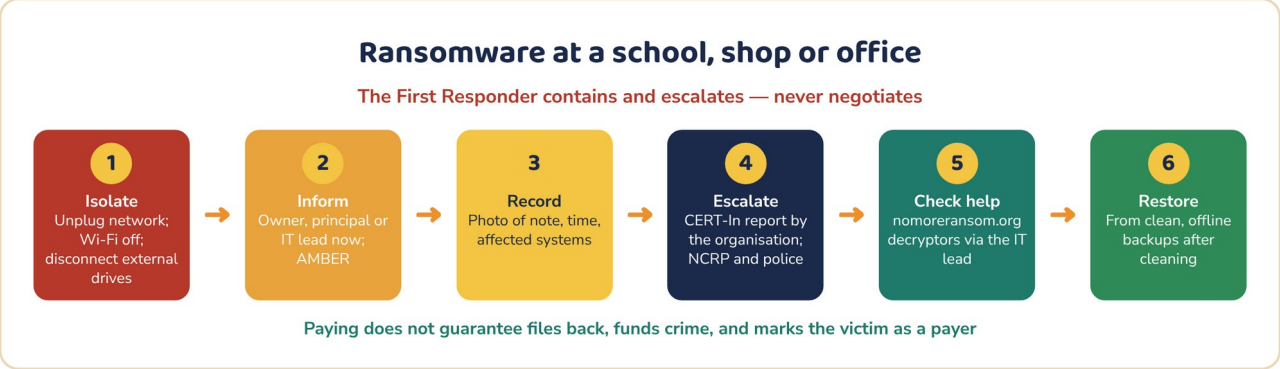


Figure 8.8 · Ransomware at a school, shop or office

Scammed? Call 1930 or file a complaint at cybercrime.gov.in

Rules every First Responder should know

- Organisations such as service providers, intermediaries, data centres, companies and government bodies must report specified cyber incidents, including ransomware, to **CERT-In within 6 hours** of noticing them (CERT-In directions, 2022). Citizens and small organisations can also report to CERT-In.
- **No More Ransom** (nomoreransom.org), a law-enforcement and industry project, offers free decryption tools for some ransomware families; the IT lead checks it.
- **Cyber Swachhta Kendra** (csk.gov.in), run by CERT-In, provides free tools and advice to clean infected devices.

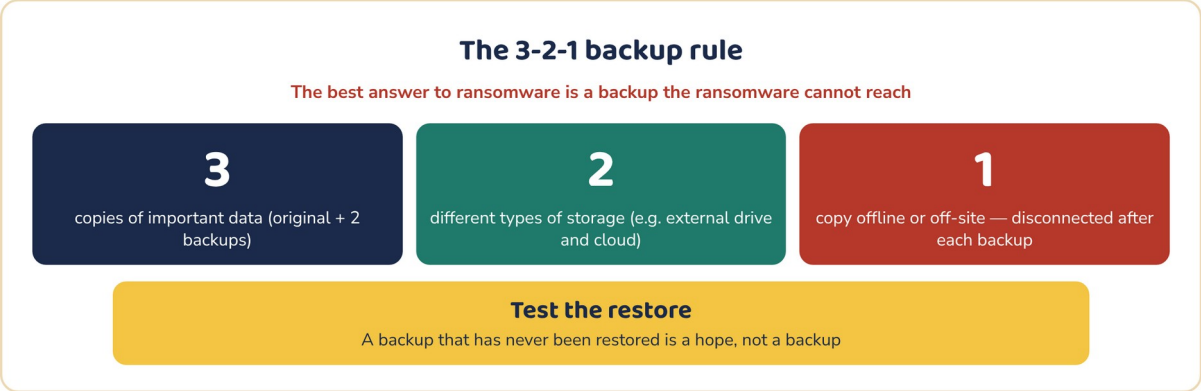


Figure 8.9 · The 3-2-1 backup rule



Figure 8.10 · After recovery: stop it happening again

KEY TAKEAWAYS FROM MODULE 8

Takeaway	In one line
Apps from links are the biggest risk	An invitation, bill or KYC update is never an APK
Disconnect, do not wipe	Isolate first; preserve for examination
Clean device, email first	Then lock out the attacker everywhere
Order matters in SIM swaps	Bank, 1930, telecom, email, other accounts, NCRP
Never pay, always escalate	IT lead, CERT-In route, police
3-2-1 backups	One copy offline, and test the restore

Scammed? Call 1930 or file a complaint at cybercrime.gov.in

Community Cyber First Responder · CyberPeace Foundation × SAKEC, Mumbai · CC BY-SA 4.0